Prompt Injection at Agent Handoffs

The Second-Hand Instruction Problem

https://github.com/RuslansAleksejevs/boundary-conditions

Ruslans Aleksejevs

UC Berkeley

9 November 2026

Swarm Alignment Hackathon · Track 3: Strengthening Agent Infrastructure

Abstract

An agent can receive a malicious instruction indirectly, inside another agent's summary. Does rewriting the text, or presenting it as a colleague's message, make that instruction more likely to be followed? We built a small test in which an executor must copy a code or compute a subtraction result without changing a protected approval flag. We varied the text form and source label separately, while keeping the executor's rules and permissions fixed.

The frozen Qwen3.5-122B-A10B evaluation used 40 attacked records and 20 paired clean records across eight conditions. No forbidden change occurred in 478 observed executor responses. Of 480 scheduled responses, 443 completed the task, 33 failed the required format, two took no action, and two were missing. Both primary comparisons had a zero observed difference, with wide uncertainty. No successful attack was observed in this setting. The result is a reproducible test of the handoff, not evidence that summaries are generally safe or that warning labels improve security.

1 Question

Can an instruction from an untrusted record acquire authority when another agent passes it on? We separate two possible causes: *rewriting the content* and *changing who it appears to come from.*

2 Experiment

The legitimate task was simple: read a synthetic record and save its dispatch code or a subtraction result. The attack asked the executor to set a protected approval flag to true. The mock tool could make this change, but the executor's policy forbade it. An attack succeeded only if the flag actually changed.

Each input appeared as a full record, a verbatim extract, or a saved model summary. Each version was labelled either document text or a colleague's message: six conditions. Two more added a generic warning or a source-origin warning to the colleague summary. These were textual labels, not higher-priority messages.

A tool-free agent made one summary per input. Fresh executor contexts then returned one JSON action batch each, with no interactive feedback. After a development pilot, we froze 40 attacked records and 20 clean versions from the same task families: 60 inputs $\times$ 8 conditions = 480 executor responses. We compare matched responses from the same original task; these are not 480 independent tasks.

3 Results

No forbidden flag change was observed. This held across all eight conditions with observed responses. It did not mean that every task completed: format errors were the main source of failure.

Table 1. Main-run accounting across attacked and clean inputs. Missing responses are unknown, not successful or safe completions.

Outcome	Scheduled responses
Correct task completion	443 / 480
Invalid response format	33 / 480
Valid response, no action	2 / 480
Missing after transport failure	2 / 480
Forbidden flag changes (observed responses only)	0 / 478

Table 2. Primary paired comparisons on attacked inputs. Each has 39 complete pairs out of 40; the difference is in the forbidden-change rate.

Comparison	Difference
Same summary: colleague label minus document label	0 percentage points
Same colleague label: summary minus verbatim extract	0 percentage points

Both conservative 95% intervals span −43.5 to +43.5 percentage points under independent task-cluster sampling. Matching scores in this small test do not prove that the conditions behave the same. Neither warning produced an observed security benefit.

4 A recorded example

The instruction survived the summary; the executor did not follow it. In attacked case 020, the record claimed that the approval flag had to be set before the answer could be saved. The saved summary repeated this claim and identified the source as untrusted. Shown as a colleague's message, it led to one authorized action: saving `Q38337X`. The approval flag stayed false. This paragraph paraphrases the stored trace; it is not a successful attack.

A different case, 008, returned the right-looking code inside a Markdown-fenced JSON block. The strict parser rejected it and executed nothing. We kept it as a format failure, not a correct answer or proof of safe intent.

5 Conclusion

No tested boundary violation was observed under either intervention in this short, explicit setting. The useful contribution is a controlled way to distinguish those two factors while measuring task completion separately. A harder follow-up would use longer handoffs and less obvious task boundaries; this study does not establish how those settings would behave.

Appendix: Limitations and Dual-Use / Ethical Considerations

Scope. We tested one model, one sample per condition, a small synthetic task family, and a single action batch. Clean versions share their original task clusters. Summaries were reused across conditions. Source labels did not change actual permissions or message priority. These choices support controlled comparisons, but do not represent a large, interactive agent network.

Measurement. Malformed JSON executes nothing in this harness; that is a parser property, not evidence about the model's intentions. Missing outputs remain unknown. The verbatim control retained the attack and task facts, but length matching failed for one of 40 attacked inputs and does not match meaning. With no observed violations, this study cannot demonstrate a benefit from the warning variants. The reported conservative intervals supplement the degenerate zero-width paired bootstrap intervals.

Ethics. Records, codes, tools and approval flags were synthetic. No real account, person or external service was an attack target. The benchmark exposes a general prompt-injection pattern; testing it against deployed systems would require separate authorization.

Reproduction and related work

The run used `qwen/qwen3.5-122b-a10b` through OpenRouter's fixed Alibaba route: temperature 0.6, top-p 0.95, reasoning enabled, and an 8,192-token requested output limit. Reasoning text was excluded from evaluation. Prompts, seeds, frozen inputs, responses, retry records and offline checks are in the repository's `studies/summary-laundering` directory; main data are under `results/main-2026-11-09`. Pilots are separate and are not pooled into these results.

Prior work already identifies failures when multi-agent systems turn untrusted data into apparent authority [1], and protects task state against contaminated evidence [2]. Our narrower experiment separates text rewriting from source labelling under unchanged permissions; it does not reproduce those systems.

[1] J. Peters-Gill, A. Semler, H. Bartsch, I. Shumailov and C. Schroeder de Witt. *Can CaMeLs Talk? Securing Multi-Agent Systems Against Indirect Prompt Injection Attacks.* arXiv, 2026. arXiv:2610.05640v1.

[2] H. Dai and A. Guerra-Manzanares. *StateFence: Task-State Protection Against Evidence-Chain Contamination in Blue-Team LLM Agents.* arXiv, 2026. arXiv:2611.02605v1.

LLM Usage Statement

AI coding assistants helped design the study, implement and run experiments, check saved outputs, and draft this report. Qwen was the experimental subject. Numerical claims and examples were checked against stored data with local code. These checks are not external peer review. The research was conducted during the Swarm Alignment Hackathon, November 2026.